Краткая сводка

В ходе тестирования на проникновение учебной машины Mr Robot CTF был получен полный контроль над системой с правами root. Найдены все три ключа (Key 1, Key 2, Key 3).

Атака проводилась по следующей цепочке: обнаружение конфиденциальных файлов через `robots.txt`, получение учётных данных WordPress, получение обратной оболочки, извлечение и взлом MD5-хеша пользователя robot и повышение привилегий через неправильно настроенный бинарный файл Nmap.

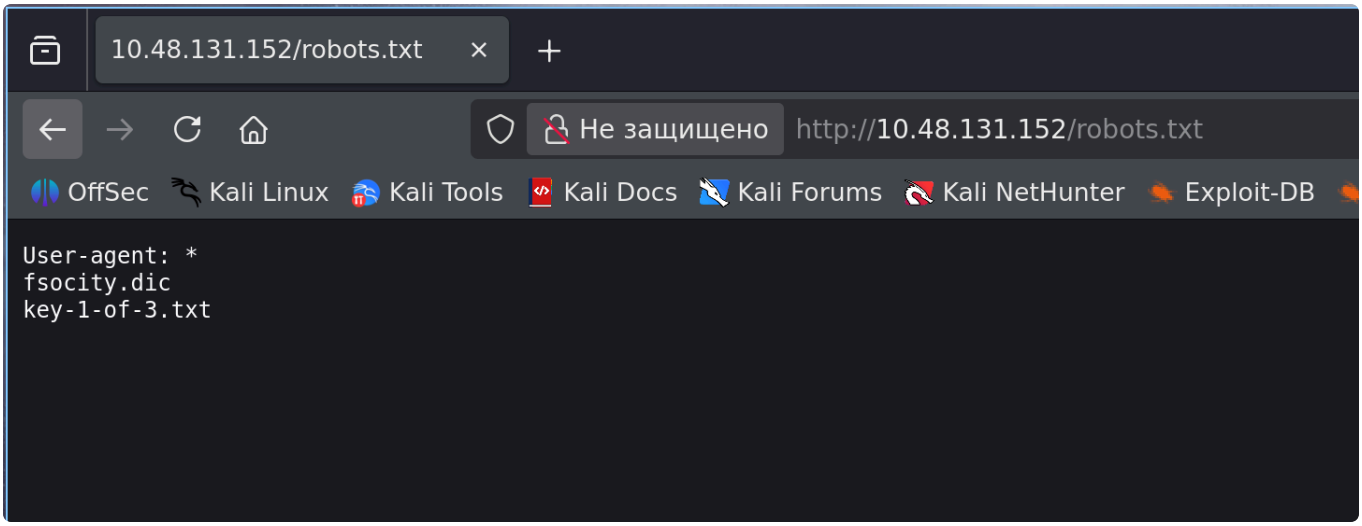
Уровень критичности: Высокий (полная компрометация системы).

Использованные инструменты

- RustScan / Nmap — сканирование портов и служб.
- Feroxbuster — поиск скрытых директорий.
- Hydra — проверка учётных данных.
- John the Ripper — взлом MD5-хеша.
- Netcat — получение обратной оболочки.
- Base64 — декодирование учётных данных.

Анализ веб-сервера

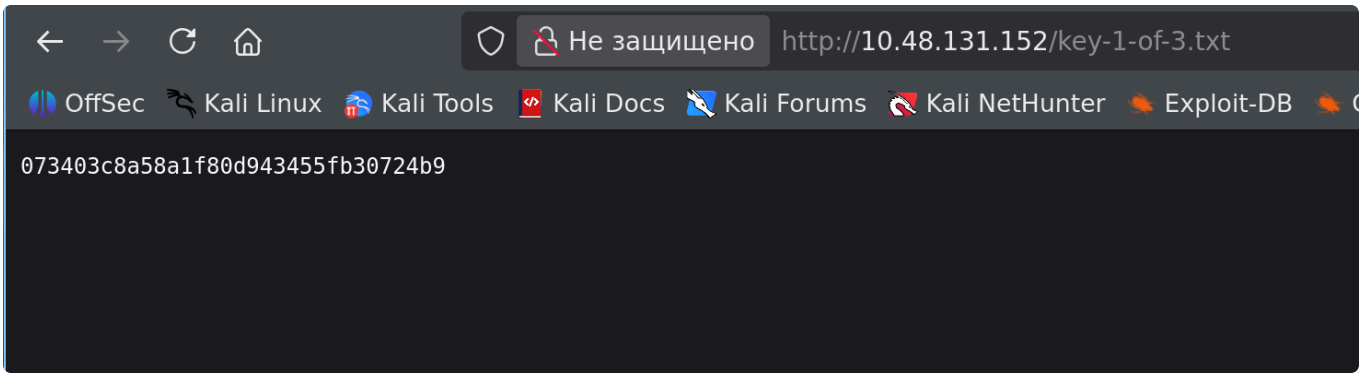
В ходе исследования веб-сервера обнаружен файл `robots.txt`.



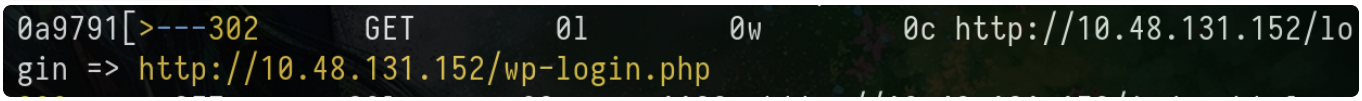
Его содержимое:

- `fsocity.dic` — словарь для дальнейшего исследования.
- `key-1-of-3.txt` — первый ключ.

Получен первый ключ машины.

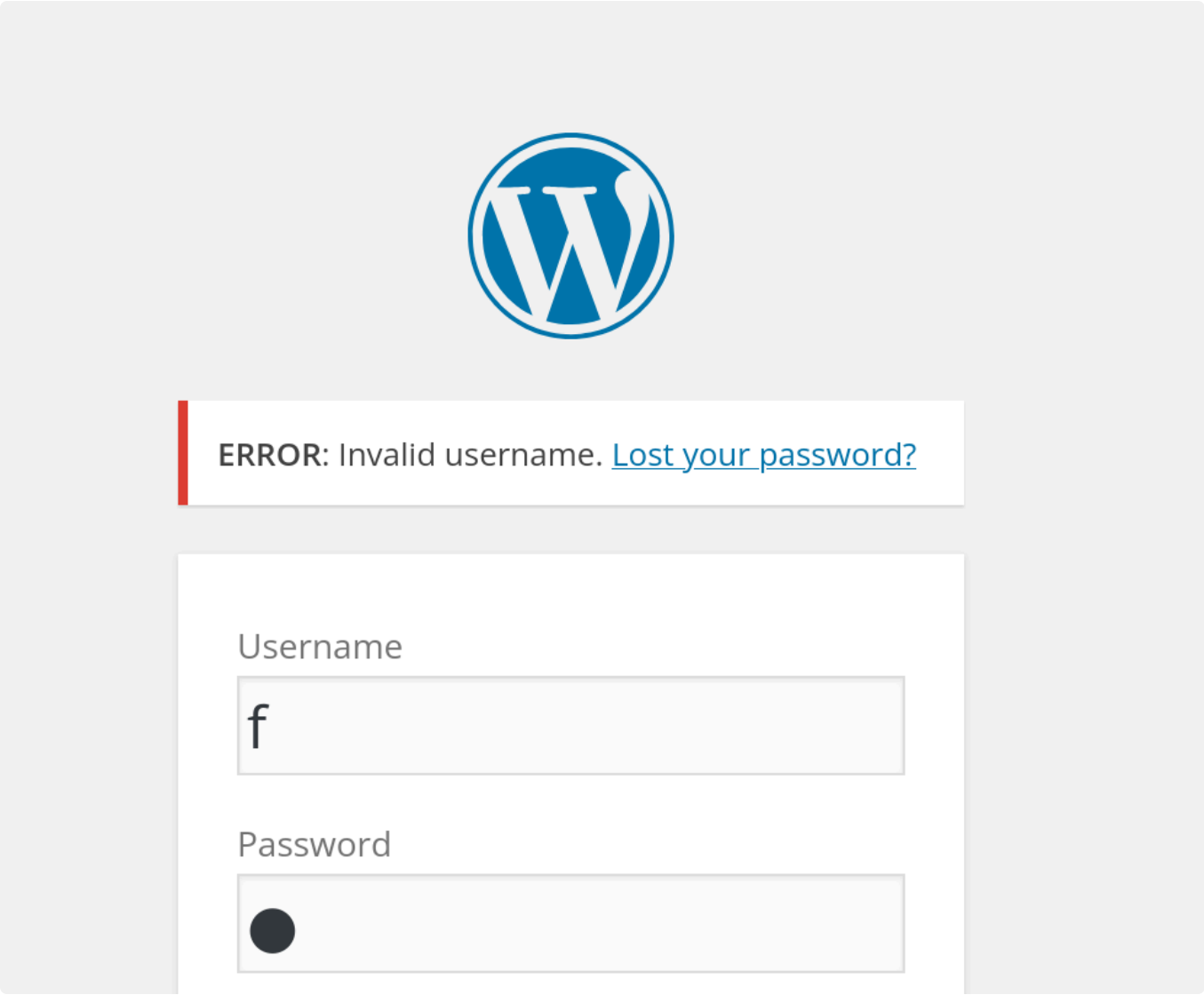


Далее обнаружена CMS WordPress и страница авторизации `/wp-login.php`.



Получение учётных данных Elliot

Заметили, что word-press отвечает на попытку авторизации следующим образом:



Значит, мы можем подобрать имя пользователя и пароль с помощью hydra и словаря данного в robots.txt(fsocity.txt)

```
➜ ~ hydra -L fsocity.txt -p test 10.48.131.152 http-post-form "/wp-l
ogin.php:log=^USER^&pwd=^PASS^&wp-submit=Log+In:F=Invalid username"
```

Получили логин Elliot:

```
[80][http-post-form] host: 10.48.131.152   login: Elliot   password:
```

Далее, подставим Elliot в логин и взломаем пароль

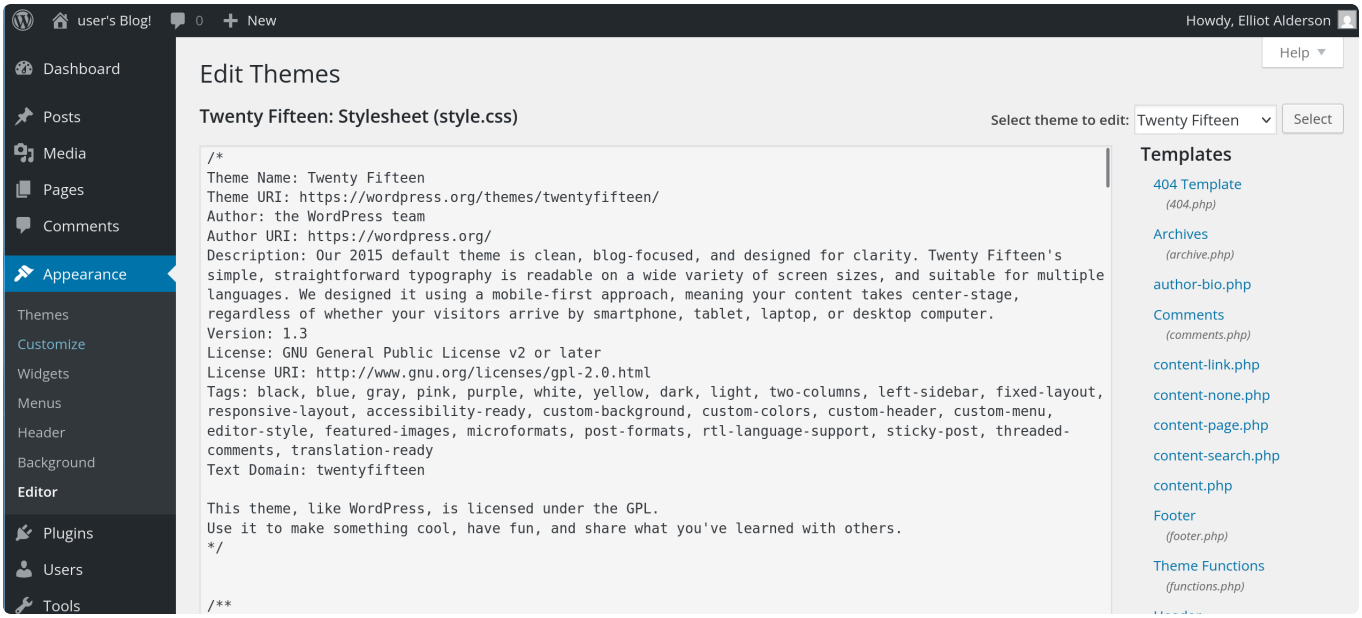
```
➜ ~ hydra -l Elliot -P fsocity_uniq.txt -t 64 10.48.131.152 http-post-fo
rm "/wp-login.php:log=^USER^&pwd=^PASS^&wp-submit=Log+In:F=The password y
ou entered for the username"
```

Получили пароль ER28-0652:

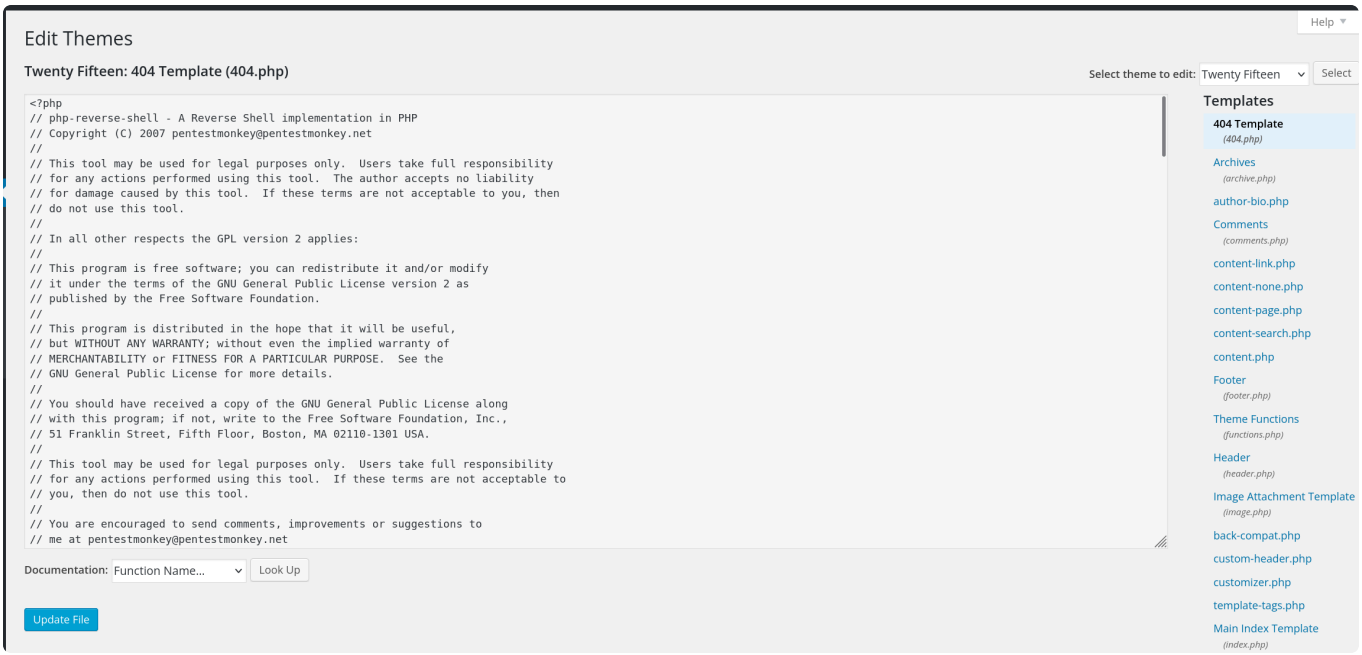
```
[80][http-post-form] host: 10.48.131.152   login: Elliot   password: ER28
-0652
```

Первоначальный доступ

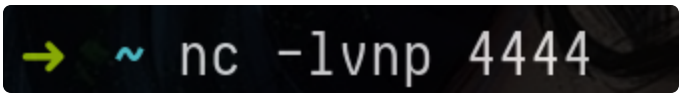
После авторизации в WordPress использована возможность редактирования PHP-шаблонов сайта.



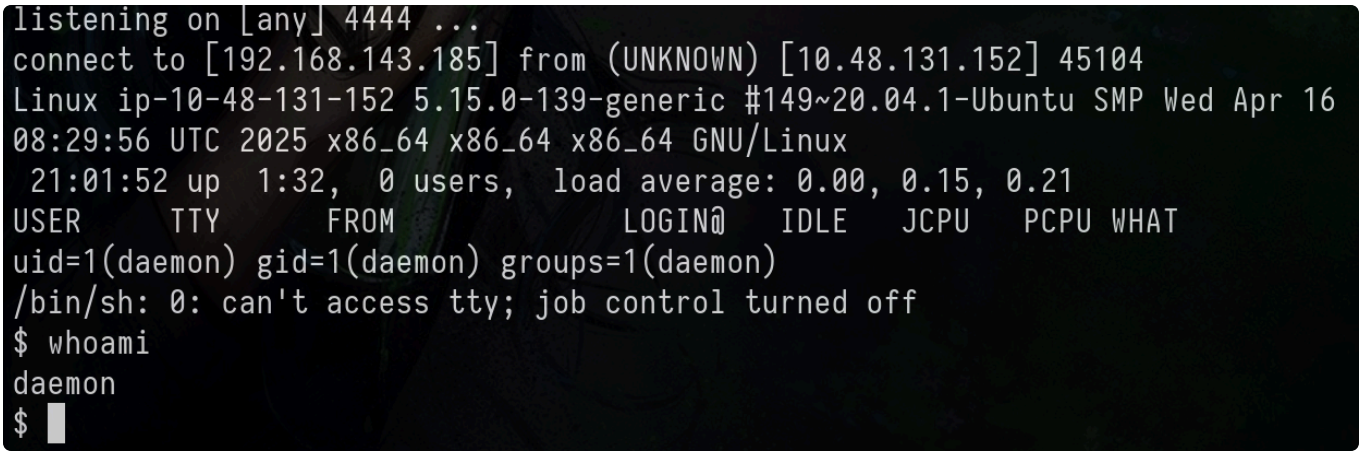
Отредактируем страницу 404



Вставили MonkeyShell и открываем порт:



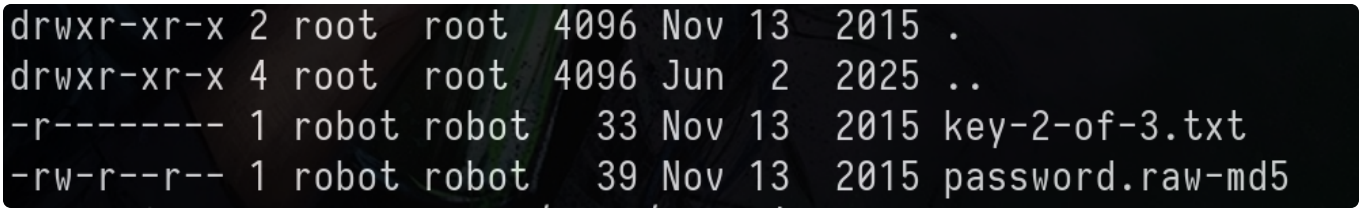
В результате удалось получить обратную оболочку (Reverse Shell) и первоначальный доступ к системе от имени пользователя `daemon`.



Получение доступа пользователя robot

В ходе исследования файловой системы обнаружена директория `/home/robot`.

В ней найдены два интересующих файла:



Первый файл недоступен для чтения текущему пользователю.

Второй файл содержит MD5-хеш пароля пользователя robot:



`robot:c3fcd3d76192e4007dfb496cca67e13b`

Взлом хеша

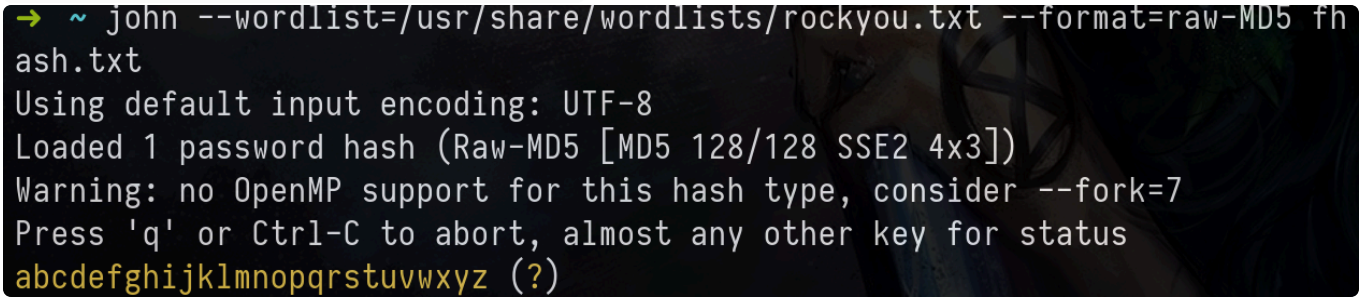
Для восстановления пароля использован John the Ripper со словарём `rockyou.txt`.

Команда:

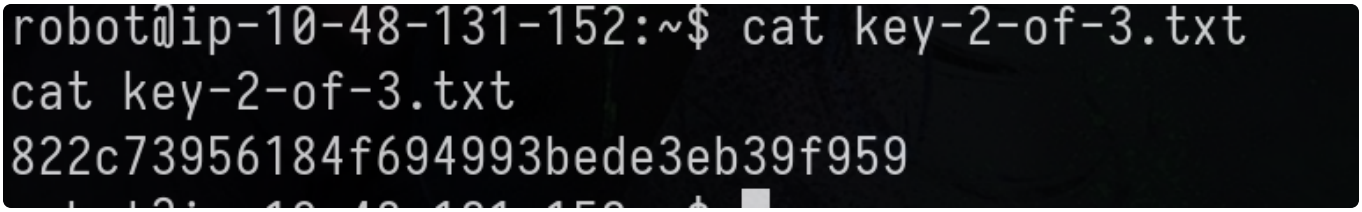
```
john --wordlist=/usr/share/wordlists/rockyou.txt --format=raw-MD5 fhash.txt
```

В результате удалось подобрать исходный пароль:

`abcdefghijklmnopqrstuvwxyz`



Таким образом, получены учётные данные пользователя robot.



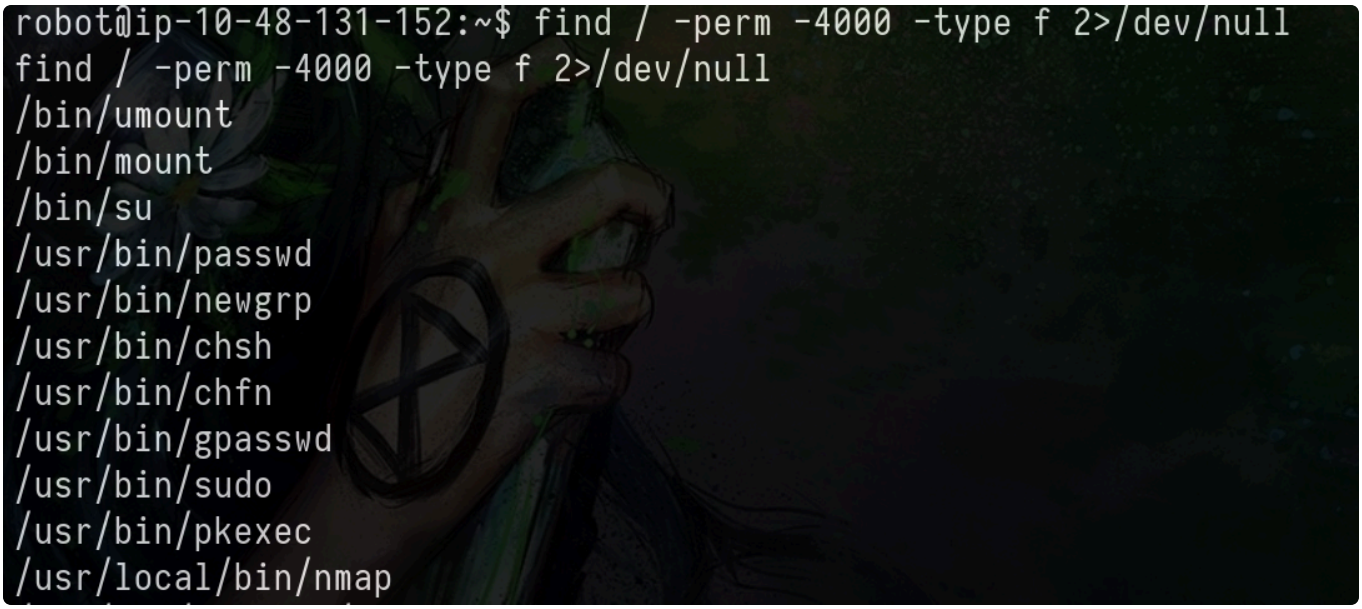
После переключения на пользователя robot стал доступен файл `key-2-of-3.txt`.

Второй ключ получен.

Повышение привилегий до Root

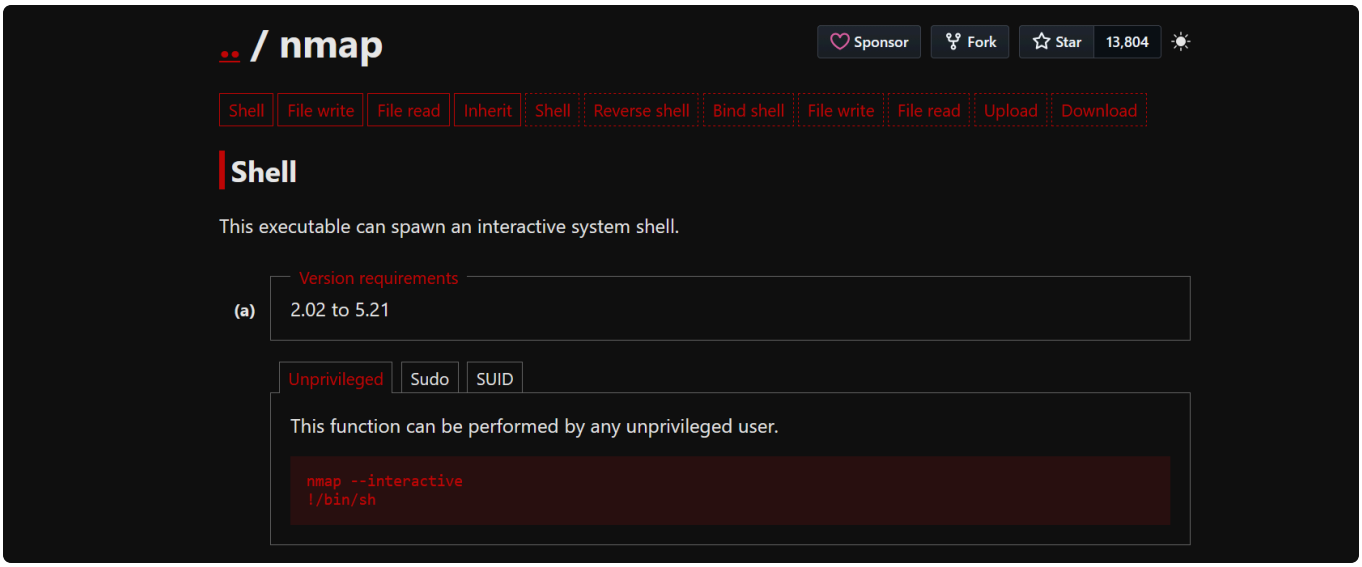
Для поиска возможных путей повышения привилегий исследованы бинарные файлы с установленным SUID-битом.

find / -perm -4000 -type f 2>/dev/null



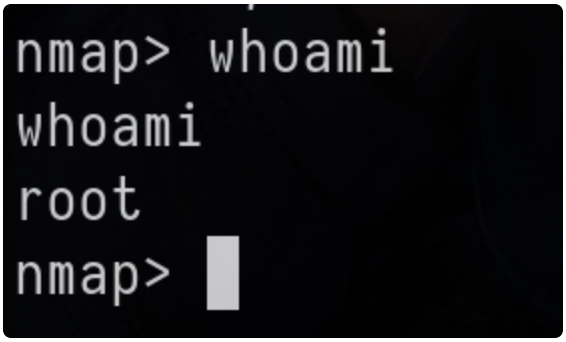
Обнаружен бинарный файл Nmap, расположенный по пути `/usr/local/bin/nmap`.

На https://gtfobins.org/gtfobins нашли shell для nmap.

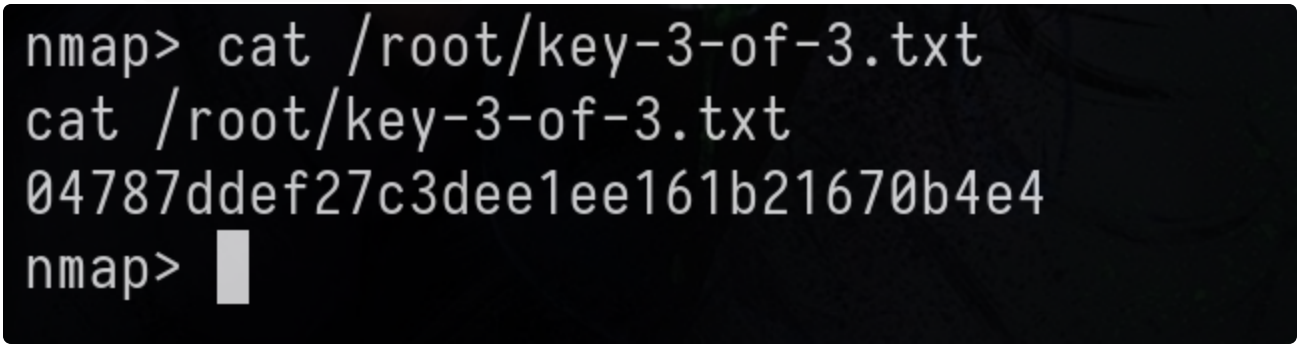


Установлено, что Nmap имеет некорректно настроенные права доступа, позволяющие использовать его для повышения привилегий.

С помощью интерактивного режима Nmap получена оболочка с правами root.



После повышения привилегий получен доступ к директории `/root` и файлу `key-3-of-3.txt`.



Третий ключ получен. Полный доступ к системе достигнут.

Рекомендации по устранению

1. **Защитить конфиденциальные файлы:** не размещать словари, ключи и другие чувствительные данные в публично доступных директориях.
2. **Защитить учётные данные WordPress:** не хранить логины и пароли в открытом или закодированном Base64 виде.
3. **Ограничить права WordPress:** запретить редактирование PHP-шаблонов через административную панель.
4. **Использовать надёжные пароли:** исключить простые и словарные пароли.
5. **Защитить хеши паролей:** использовать современные алгоритмы хеширования паролей с солью, например Argon2id.
6. **Исправить SUID-права:** удалить SUID-бит с Nmap, если он не требуется для работы системы.
7. **Применять принцип наименьших привилегий:** ограничить возможности пользователей и исполняемых файлов.